

# Polaris Claims Hub Compliance and Security Handbook

**Filename:** 04\_compliance\_security\_handbook.md

**Document type:** Policy / Compliance Handbook

**Date:** 2026-01-30

**Owner:** Mara Kline, Chief Compliance Officer

**Status:** Governing policy for 2026 operations

**Related documents:** 01\_project\_meridian\_prd.md, 02\_meridian\_architecture\_design.md, 08\_customer\_onboarding\_guide.md

## Purpose Summary

This handbook defines compliance and security expectations for Polaris Claims Hub, including data classification, role-based access, audit logging, retention, customer communication, incident reporting, and permitted uses of workflow recommendations.

## Data Classification

Northstar Benefits Group classifies data into four categories:

**Public:** Approved marketing content and public product documentation.

**Internal:** Operational procedures, non-sensitive project plans, team roadmaps, and aggregated metrics that do not identify claimants.

**Confidential:** Customer contract terms, employer group configuration, carrier mappings, internal support notes, and security architecture.

**Restricted:** Protected health information, employee claim evidence, disability-related documents, diagnosis or treatment references, government identifiers, bank details, and any claim note that could reveal health status.

Meridian workspace data may include all four categories. The default assumption for uploaded evidence is Restricted until classified otherwise.

## Role-Based Access

The following roles are approved:

- Operations Adjudicator: may view claim evidence, eligibility summary, checklist, recommendation details, and decision history for assigned tenants.
- Support Specialist: may view claim summary, public status, safe evidence metadata, and escalation reason. May not view evidence content by default.
- Support Lead: may view Support Specialist fields plus internal status and escalation notes.

- Compliance Reviewer: may view audit history, evidence metadata, and evidence content when assigned to a review or investigation.
- Security Analyst: may view access logs, audit events, and limited metadata necessary for security investigation.
- Carrier Integration Analyst: may view carrier mapping metadata and sync payload status. Evidence content requires separate reviewer access.
- Broker User: may view employer-approved operational status and safe summary fields. Broker PHI access requires a signed addendum and Security approval.
- Customer Benefits Administrator: may view claims for their employer group according to customer configuration and employee consent rules.

Access must be least privilege. Group-based access must be reviewed quarterly. Emergency access is allowed only through break-glass workflow and requires a reason code.

## Audit Logging

All claim-changing actions must produce audit events. Events must capture actor, role, timestamp, tenant, claim ID, action, prior value, new value, source service, and request ID. Displaying a recommendation must be logged when it could influence a human review. Audit export itself must also be logged.

Audit logs are append-only. Engineering teams may replay event delivery from an outbox when idempotency keys are intact, but may not edit audit records directly. Corrections must be appended as corrective events.

## Retention

Claim records, evidence files, evidence metadata, audit events, recommendation records that were displayed to users, and decision history must be retained for seven years after claim closure unless a customer contract, legal hold, regulatory inquiry, or litigation preservation notice requires longer retention.

Temporary extraction artifacts, draft classification traces, and non-displayed recommendation evaluation details should be deleted within 30 days unless needed for an active incident review. Backups follow the approved backup lifecycle and are not used as searchable production records.

If a claim is reopened, the retention clock is interpreted conservatively. Compliance guidance is to retain until seven years after final closure of the reopened claim. The PRD lists this as an open product question because the UI timer behavior is separate from legal retention.

## Workflow Recommendations

Recommendations are permitted only as workflow aids. They must not make final benefit determinations or communicate decisions to employees. Recom-

recommendation language must avoid words such as “deny,” “approve,” or “medically necessary” unless presented as a recorded human decision from an authorized adjudicator.

Allowed examples: - Missing provider statement. - Possible duplicate claim. - Eligibility data unavailable. - Carrier mapping error. - Ready for human review.

Prohibited examples: - Claim should be denied. - Employee is not disabled. - Fraud likely. - Medical evidence insufficient for benefit approval.

## **Customer Communications**

Missing information requests must use approved templates. Free-text notes may be added, but required compliance language may not be removed. Customer communications must not expose internal model confidence scores, internal rule IDs, or Security investigation notes.

Brokers may receive operational delay explanations, but medical evidence details must not be included unless broker PHI access is contractually enabled and technically approved.

## **Incident Reporting**

Suspected unauthorized access, cross-tenant exposure, missing audit history for claim-changing actions, or Restricted data leakage must be reported to Security immediately. Security determines notification obligations with Legal and Compliance. Operations incidents without data exposure follow the standard SRE incident process.

For incidents involving Restricted data, the incident record must include data categories involved, affected tenants, affected claim count, detection source, containment steps, and whether any evidence content was accessed.

## **Vendor and Carrier Integrations**

Carrier integrations must use approved transport, encryption, and authentication methods. Carrier payloads should include the minimum necessary information. Failed payloads may be logged only with identifiers, error categories, and sanitized metadata. Full payload capture requires Security approval for a bounded investigation window.

## **Training**

Employees with access to Restricted claim data must complete annual privacy and security training. Meridian pilot users must complete supplemental training covering role-based workspace views, recommendation limitations, missing information templates, and incident escalation.

## **Exceptions**

Policy exceptions require a named owner, expiration date, risk acceptance, and compensating controls. The broker-phi-view feature flag is considered a high-risk exception and must expire within 12 months unless renewed.

## **Appendix: Policy Conflicts and Interpretation**

If product documentation conflicts with this handbook, the handbook governs. If architecture documentation describes a longer implementation buffer, such as seven years plus 30 days, that buffer is operational and does not change the retention policy. If customer contract terms require longer retention, contract terms govern.